
**CONCEPTO
ARQUITECTURA EMPRESARIAL
ACTIVACIÓN DE PIN PARA TARJETAS PREPAGO
INNOMINADAS
CREDIBANCO**

VERSIÓN 1.0

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
30/04/2026	1.0	Versión Inicial	Javier Ricardo Agudelo

TABLA DE CONTENIDO

HISTORIA DE REVISIONES	2
TABLA DE CONTENIDO	3
GUÍA DE USO	4
NECESIDAD.....	5
PREMISAS DEL CONCEPTO	6
LINEAMIENTOS	7
RESTRICCIONES	8
ARQUITECTURA PROPUESTA	9
Diagrama de Arquitectura.....	10
Descripción de componentes	11
Descripción del proceso.....	12
Controles de seguridad propuestos.....	14
Riesgos identificados.....	15
Aplicaciones y/o soluciones afectadas	15
ANEXOS.....	17

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.
- No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".
- No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.
- Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.

NECESIDAD

El presente concepto se enfoca en definir la arquitectura propuesta para el flujo de activación de PIN de tarjetas prepago innominadas, permitiendo que el tarjetahabiente pueda asignar su PIN de forma digital, segura y sin requerir enrolamiento previo en el Portal Tarjetahabiente.

La necesidad surge porque las tarjetas prepago innominadas se crean sin datos de identificación del tarjetahabiente. Por lo tanto, no se cuenta previamente con correo electrónico, teléfono, documento de identidad ni usuario registrado en el portal.

Adicionalmente, se identifican restricciones operativas sobre los canales tradicionales de asignación de PIN, tales como pinpad físico, ATM, canal presencial o portal autenticado. También se descarta el uso de códigos QR impresos en el carrier, debido a que el realizador no cuenta con capacidad para imprimir tokens visuales personalizados.

Las necesidades principales son:

- Permitir la activación digital de PIN para tarjetas prepago innominadas.
- Validar que quien realiza la activación tenga posesión física de la tarjeta.
- Evitar el uso de un portal autenticado, dado que no existe usuario previamente enrolado.
- Reutilizar el iframe seguro de captura de PIN ya definido para tarjetas nominadas.
- Evitar que el micro-portal público capture, procese o almacene el PIN.
- Garantizar que el PIN nunca viaje ni permanezca en claro fuera del iframe seguro y del HSM.
- Re-cifrar el PIN en HSM antes de enviarlo al proveedor Pomelo.
- Mantener trazabilidad, control de intentos, idempotencia y auditoría del proceso.
- Definir claramente el alcance PCI/CDE del flujo.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta.

- El flujo aplica únicamente para tarjetas prepago innominadas.
- Las tarjetas innominadas no cuentan con identificación previa del tarjetahabiente.
- El tarjetahabiente no tiene usuario creado en el Portal Tarjetahabiente.
- La activación debe iniciar desde una URL pública informada en el carrier genérico, sitio web de la entidad emisora o folleto físico.
- El micro-portal será una aplicación web mínima, sin login, sin sesión persistente y sin funcionalidades transaccionales adicionales.
- La validación inicial se realizará bajo un modelo de Proof of Possession, solicitando datos visibles en la tarjeta física.
- El micro-portal validará posesión de tarjeta, pero no capturará ni procesará el PIN.
- El iframe seguro de PIN estará alojado en un dominio separado controlado por Credibanco.
- El iframe será el único componente frontend autorizado para capturar el PIN.
- El backend actuará como proxy opaco del PIN cifrado y no tendrá capacidad de descifrarlo.
- La criptografía sensible del PIN se realizará exclusivamente mediante HSM Thales payShield.
- El PIN será re-cifrado en HSM con la llave pública de Pomelo antes de enviarse al proveedor.
- La comunicación backend-HSM deberá realizarse por mTLS.
- La comunicación backend-Pomelo deberá realizarse por VPN y mTLS.
- La sesión de activación será efímera, de un solo uso y con TTL máximo de 5 minutos.
- Todo el flujo deberá contar con auditoría end-to-end mediante correlationId.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta.

- Se deberá aplicar el principio de mínima exposición de datos.
- El micro-portal público deberá limitarse exclusivamente a la verificación de posesión de la tarjeta.
- El micro-portal no deberá renderizar teclado de PIN ni ejecutar lógica criptográfica de PIN.
- El iframe seguro deberá operar en un dominio independiente, por ejemplo secure-pin.credibanco.com.
- El micro-portal no deberá poder leer el DOM ni el contenido interno del iframe.
- La comunicación entre micro-portal e iframe deberá limitarse a mensajes estrictamente necesarios mediante postMessage.
- Los mensajes enviados al iframe no deberán incluir PAN completo, CVV2 ni PIN.
- El iframe deberá recibir únicamente un identificador interno de tarjeta y un token de sesión efímero.
- La captura del PIN deberá realizarse con teclado enmascarado.
- El iframe deberá bloquear autocomplete, copy, paste y cut.
- El PIN deberá cifrarse en el navegador usando SubtleCrypto con RSA-OAEP.
- Después del cifrado, el PIN deberá eliminarse de memoria en el navegador.
- El backend no deberá registrar PIN, CVV2 ni datos sensibles en logs.
- El HSM deberá ser el único componente autorizado para descifrar y re-cifrar el PIN.
- El PIN en claro solo podrá existir dentro del entorno protegido del HSM.
- Se deberá implementar nonce anti-replay y timestamp en el bloque cifrado.
- Se deberá usar idempotencyKey para evitar doble asignación de PIN.
- Se deberán implementar controles de rate limiting, CAPTCHA y bloqueo por intentos.
- Se deberá mantener auditoría completa del flujo sin registrar datos sensibles.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta.

- No existe usuario autenticado para la tarjeta innominada.
- No se dispone de email, teléfono ni documento de identidad del tarjetahabiente.
- No es viable usar Portal Tarjetahabiente autenticado para iniciar el proceso.
- No es viable usar QR impreso en el carrier por limitación del realizador.
- El canal presencial, ATM y pinpad físico fueron descartados como mecanismo principal del flujo digital.
- La activación depende de que la tarjeta esté en estado pendiente de activación.
- El flujo depende de la disponibilidad del micro-portal público.
- El flujo depende de la disponibilidad del backend de activación.
- El flujo depende de la disponibilidad del HSM Thales payShield.
- El flujo depende de la disponibilidad de Pomelo para confirmar la asignación del PIN.
- La sesión de activación debe expirar en un tiempo corto.
- La superación de intentos fallidos debe bloquear la activación digital.
- Si la activación digital se bloquea, el tarjetahabiente deberá acudir a un canal definido por la entidad emisora.
- El flujo debe ser revisado por Seguridad de la Información debido al uso de CVV2 como factor de prueba de posesión.
- El alcance PCI/CDE deberá ser validado formalmente, dado que aunque el micro-portal no captura PAN completo, sí interviene en la captura de datos de tarjeta usados para validar posesión.

ARQUITECTURA PROPUESTA

La arquitectura propuesta se compone de dos bloques funcionales separados:

1. **Micro-portal público de activación**, encargado únicamente de verificar la posesión de la tarjeta.
2. **Iframe seguro de captura de PIN**, encargado de capturar, cifrar y enviar el PIN bajo un modelo criptográfico controlado por Credibanco y HSM.

El flujo inicia cuando el tarjetahabiente recibe una tarjeta prepago innominada y accede a una URL pública de activación. En el micro-portal ingresa datos visibles de la tarjeta para demostrar posesión física. Una vez validada la información, el backend genera una sesión efímera de activación y habilita la carga del iframe seguro de PIN.

El iframe solicita una llave pública efímera generada por el HSM, captura el PIN, lo cifra en el navegador y envía únicamente el ciphertext al backend. El backend no descifra el PIN; actúa como intermediario hacia el HSM. El HSM descifra internamente el bloque recibido, valida controles anti-replay y re-cifra el PIN con la llave pública de Pomelo. Finalmente, el backend envía el PIN re-cifrado al proveedor Pomelo mediante un canal seguro.

Descripción de componentes

Identificador	Componente	Descripción
CSA-001	Tarjetahabiente	Persona que posee físicamente la tarjeta prepago innominada y requiere activar el PIN.
CSA-002	Carrier genérico / canal informativo	Medio donde se comunica la URL pública de activación. Puede ser texto impreso, folleto o sitio de la entidad emisora.
CSA-003	Micro-Portal Activación	Aplicación web pública mínima que permite iniciar el flujo y validar posesión de tarjeta. No captura PIN.
CSA-004	Formulario Proof of Possession	Formulario donde el tarjetahabiente ingresa entidad emisora, últimos 4 dígitos del PAN, fecha de vencimiento y CVV2.
CSA-005	CAPTCHA	Control anti-bot para reducir ataques automatizados sobre el formulario público.
CSA-006	Backend Activación	Servicio backend encargado de validar posesión, generar sesión efímera, coordinar el iframe y orquestar la comunicación con HSM y Pomelo.
CSA-007	Base de datos de tarjetas	Repositorio donde se consulta la existencia de la tarjeta, estado pendiente de activación y datos mínimos requeridos para validación.
CSA-008	Redis / almacenamiento efímero	Repositorio temporal para sessionToken, llaves efímeras protegidas y estado transitorio del flujo.
CSA-009	Iframe PIN Seguro	Componente frontend en dominio separado, responsable de capturar el PIN y cifrarlo antes de enviarlo al backend.
CSA-010	HSM Thales payShield	Hardware criptográfico responsable de generar llaves efímeras, descifrar internamente el bloque recibido y re-cifrar el PIN para Pomelo.
CSA-011	Pomelo API	Proveedor externo que recibe el PIN re-cifrado y confirma la asignación del PIN.
CSA-012	Módulo de auditoría	Componente lógico para registrar eventos, intentos, estados, IP, user-agent, resultado y correlationId.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

Fase 0. Preparación de tarjeta innominada

Al crearse una tarjeta prepago innominada por batch o API, el backend genera un identificador interno de tarjeta. La tarjeta queda registrada en estado pendiente de activación.

El sistema debe almacenar la información mínima necesaria para permitir la verificación posterior de posesión y activación del PIN, respetando los lineamientos PCI aplicables.

Fase 1. Acceso al micro-portal público

El tarjetahabiente accede a la URL pública de activación informada en el carrier, folleto o sitio web de la entidad emisora.

El micro-portal carga una aplicación web mínima con las siguientes condiciones:

- Sin login previo.
- Sin enrolamiento.
- Sin sesión persistente.
- Sin funcionalidades transaccionales.
- Con CSP headers estrictos.
- Con scripts controlados y, cuando aplique, SRI.
- Con formulario exclusivo para validación de posesión.

Fase 2. Verificación de posesión de la tarjeta

El tarjetahabiente ingresa los datos solicitados para demostrar que tiene la tarjeta física:

- Entidad emisora.
- Últimos 4 dígitos del PAN.
- Fecha de vencimiento.
- CVV2.
- CAPTCHA.

El backend valida la combinación recibida, verificando que:

- La tarjeta exista.
- La tarjeta pertenezca a la entidad seleccionada.
- La tarjeta se encuentre en estado pendiente de activación.
- Los datos ingresados coincidan con la información esperada.
- No se haya excedido el número de intentos permitidos.

Se permiten máximo 3 intentos fallidos por tarjeta. Al superar el límite, la activación digital se bloquea y el tarjetahabiente deberá acudir al canal definido por la entidad emisora.

Fase 3. Generación de sesión efímera

Si la validación de posesión es exitosa, el backend genera una sesión efímera de activación.

Esta sesión debe cumplir las siguientes condiciones:

- TTL máximo de 5 minutos.
- Uso único.
- Asociación al identificador interno de la tarjeta.
- Asociación al correlationId del proceso.
- Sin almacenamiento en cookies o localStorage.
- Invalidez automática después de uso, expiración o error crítico.

El backend retorna al micro-portal un token de sesión que permitirá cargar el iframe seguro de PIN.

Fase 4. Carga del iframe seguro de PIN

El micro-portal carga el iframe seguro alojado en un dominio separado, por ejemplo: `secure-pin.credibanco.com`

El micro-portal envía al iframe únicamente la información mínima necesaria:

- cardId interno o referencia equivalente.
- sessionToken efímero.
- correlationId.

No se debe enviar PAN completo, CVV2 ni PIN mediante postMessage.
El micro-portal no puede leer el DOM del iframe ni acceder al valor del PIN digitado.

Fase 5. Generación de llave pública efímera

El iframe solicita al backend una llave pública efímera para cifrar el PIN.

El backend coordina con el HSM Thales payShield la generación de la llave, usando el comando correspondiente. La llave privada queda protegida bajo LMK del HSM y no se expone en claro al backend.

El iframe recibe únicamente la llave pública para cifrado.

Fase 6. Captura y cifrado del PIN en el iframe

El iframe presenta un teclado enmascarado para que el tarjetahabiente digite y confirme su PIN.

El iframe debe aplicar los siguientes controles:

- PIN de 4 a 6 dígitos, según política definida.
- Confirmación del PIN.
- Autocomplete deshabilitado.
- Bloqueo de copiar, cortar y pegar.
- Timeout por inactividad.
- Máximo 3 intentos por sesión.
- Validación de formato.
- Cifrado inmediato usando SubtleCrypto con RSA-OAEP.
- Inclusión de nonce anti-replay.
- Inclusión de timestamp.
- Borrado de memoria posterior al cifrado.

Después del cifrado, únicamente sale del iframe el ciphertext.

Fase 7. Interchange criptográfico en HSM

El backend recibe el ciphertext del iframe y lo envía al HSM como proxy opaco. El backend no debe tener capacidad de descifrar el PIN.

El HSM ejecuta las operaciones criptográficas requeridas:

- Descifra internamente el bloque recibido.
- Valida nonce anti-replay.
- Valida timestamp.
- Re-cifra el PIN con la llave pública de Pomelo.
- Retorna únicamente el PIN re-cifrado para Pomelo.

El PIN en claro solo podrá existir dentro de la memoria protegida del HSM durante la operación criptográfica.

Fase 8. Envío a Pomelo

El backend envía a Pomelo el PIN re-cifrado mediante canal seguro.

La comunicación deberá incluir:

- VPN.
- mTLS.
- idempotencyKey.
- cardId o identificador requerido por Pomelo.
- PIN re-cifrado.
- Datos mínimos requeridos para completar la asignación.

Pomelo procesa la asignación y responde el resultado al backend.

Fase 9. Confirmación y cierre

Cuando Pomelo confirma la asignación del PIN, el backend:

- Actualiza el estado de la tarjeta a activa.
- Invalida la sesión efímera.
- Elimina información temporal en Redis.
- Registra auditoría del proceso.

- Retorna resultado al iframe.

El iframe notifica al micro-portal únicamente el estado de la operación, sin datos sensibles. El micro-portal muestra al tarjetahabiente la confirmación de activación.

Controles de seguridad propuestos

Control	Descripción
Proof of Possession	Validación con datos físicos de la tarjeta: entidad, últimos 4 dígitos, fecha de vencimiento y CVV2.
CAPTCHA	Control obligatorio para mitigar automatización sobre el micro-portal público.
Rate limiting	Límite de intentos por IP, tarjeta y sesión.
Máximo de intentos	Máximo 3 intentos fallidos por tarjeta antes de bloquear la activación digital.
Bloqueo permanente del canal digital	Si se supera el límite de intentos, se bloquea la activación digital y se deriva al canal definido por la entidad.
Separación de responsabilidades	Micro-portal autentica posesión; iframe captura PIN; HSM realiza criptografía sensible.
Dominio separado para iframe	El iframe opera en un dominio controlado por Credibanco, aislado del micro-portal.
Same-origin policy	El micro-portal no puede leer el DOM ni contenido interno del iframe.
Sesión efímera	Token de sesión de un solo uso con TTL máximo de 5 minutos.
No almacenamiento local	No uso de localStorage, sessionStorage ni cookies persistentes para datos sensibles.
Cifrado en navegador	PIN cifrado con SubtleCrypto RSA-OAEP antes de salir del iframe.
HSM	Descifrado y re-cifrado del PIN exclusivamente dentro de HSM Thales payShield.
Nonce anti-replay	Inclusión de nonce para evitar reutilización del bloque cifrado.
Timestamp	Control temporal para evitar replay fuera de ventana.
mTLS backend-HSM	Comunicación interna protegida.
VPN + mTLS backend-Pomelo	Comunicación segura con proveedor.
IdempotencyKey	Prevención de doble asignación de PIN.
Auditoría	Registro end-to-end con correlationId, IP, user-agent, timestamp y resultado.
No logging sensible	No registrar PIN, CVV2, ciphertext sensible ni datos equivalentes en logs.

Riesgos identificados

Riesgo	Mitigación propuesta
Ataque automatizado al micro-portal	CAPTCHA, rate limiting, límites por IP y bloqueo por intentos.
Adivinación de datos de tarjeta	Uso combinado de entidad, last4, expiración y CVV2, con máximo 3 intentos.
Uso indebido del CVV2	No almacenar CVV2, no loguearlo y validar con mecanismo aprobado por Seguridad/PCI.
Captura de PIN por el micro-portal	Separación estricta: el micro-portal no renderiza ni procesa el PIN.
Lectura del PIN desde el portal padre	Iframe en dominio separado y same-origin policy.
Replay del ciphertext	Nonce anti-replay, timestamp y sesión efímera de un solo uso.
Compromiso del sessionToken	TTL corto, uso único, asociación a tarjeta y validación server-side.
Doble asignación de PIN	idempotencyKey en la comunicación con Pomelo.
Exposición del PIN en backend	Backend como proxy opaco, sin llave privada ni capacidad de descifrado.
Exposición del PIN en memoria frontend	Cifrado inmediato y borrado de memoria después del cifrado.
Indisponibilidad del HSM	Manejo de error controlado, invalidación/reintento seguro y auditoría.
Indisponibilidad de Pomelo	Uso de idempotencia, control de reintentos y estado transaccional.
Ambigüedad de alcance PCI	Validación formal con Seguridad de la Información y auditor PCI.

Aplicaciones y/o soluciones afectadas

Aplicación / solución	Impacto
Sistema Prepago	Debe registrar tarjetas innominadas en estado pendiente de activación.
Micro-Portal Activación	Nueva aplicación pública para iniciar activación digital.
Backend Activación	Nuevo servicio o capacidad backend para validar posesión, crear sesión y orquestar PIN.
Base de datos de tarjetas	Consulta de estado, entidad, identificador interno y datos mínimos para validación.
Redis / caché efímera	Manejo temporal de sessionToken, llave efímera protegida y estado de sesión.
Iframe PIN Seguro	Componente reutilizable para captura y cifrado de PIN.

HSM Thales payShield	Generación de llaves efímeras, descifrado controlado y re-cifrado del PIN.
Pomelo API	Proveedor que recibe el PIN re-cifrado y confirma la asignación.
Plataforma de auditoría/logs	Registro de eventos técnicos y de seguridad.
Seguridad de la Información	Validación del modelo de riesgo, controles PCI y alcance CDE.

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.